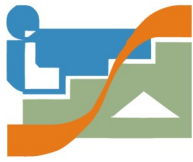


UNITAT 03

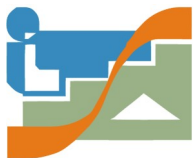
INVESTIGACIÓ d'IC



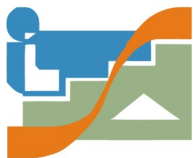


- **Recopilació d'evidències**
- **Anàlisi d'evidències (riscos)**
- **Investigació de l'incident**
- **Intercanvi d'informació de l'incident amb proveïdors o organismes competents**
- **Mesures de contenció d'incidents**





- **Recopilació d'evidències**
- **Anàlisi d'evidències**
- **Investigació de l'incident**
- **Intercanvi d'informació de l'incident amb proveïdors o organismes competents**
- **Mesures de contenció d'incidents**



Recopilació d'evidències

RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge



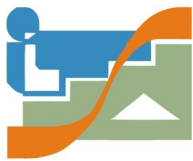
Principis durant la recol·lecció d'evidències

Procediment de recol·lecció

El procediment d'emmagatzematge

Eines necessàries

<https://www.incibe-cert.es/blog/rfc3227>

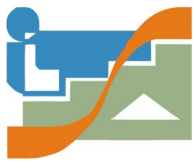


Recopilació d'evidències

RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge

Principis durant la recol·lecció d'evidències

- Capturar una imatge del sistema tan precisa com siga possible.
- Realitzar notes detallades, incloent dates i hores indicant si s'utilitza horari local o UTC.
- Minimitzar els canvis en la informació que s'està recol·lectant i eliminar els agents externs que puguen fer-ho.
- En el cas d'enfrontar-se a un dilema entre recol·lecció i anàlisi triar primer recol·lecció i després anàlisi.
- Recollir la informació segons l'ordre de volatilitat (de major a menor).
- Tindre en compte que per cada dispositiu la recollida d'informació pot realitzar-se de diferent manera.



Recopilació d'evidències

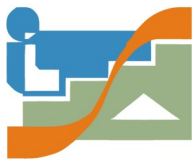
RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge

Principis durant la recol·lecció d'evidències - Ordre de volatilitat

L'ordre de volatilitat fa referència al període de temps en el qual està accessible una certa informació. És per això que s'ha de recol·lectar en primer lloc aquella informació que vaja a estar disponible durant el menor període de temps, és a dir, aquella la volatilitat de la qual siga major.

D'acord amb aquesta escala es pot crear la següent llista en ordre de major a menor volatilitat:

- Registres i contingut de la caché.
- Taula d'encaminament, cache ARP, taula de processos, estadístiques del kernel, memòria.
- Informació temporal del sistema.
- Disc
- Logs del sistema.
- Configuració física i topologia de la xarxa.
- Documents.



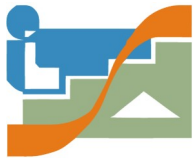
Recopilació d'evidències

RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge

Principis durant la recol·lecció d'evidències - Accions que han d'evitar-se

S'han d'evitar les següents accions amb la finalitat de no invalidar el procés de recol·lecció d'informació ja que ha de preservar-se la seua integritat amb la finalitat que els resultats obtinguts puguin ser utilitzats en un judici en el cas que siga necessari:

- No apagar l'ordinador fins que s'haja recopilat tota la informació.
- No confiar en la informació proporcionada pels programes del sistema ja que poden haver-se vist compromesos. S'ha de recopilar la informació mitjançant programes des d'un mitjà protegit com s'explicarà més endavant.
- No executar programes que modifiquen la data i hora d'accés de tots els fitxers del sistema.

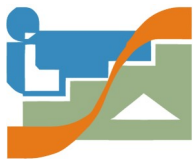


Recopilació d'evidències

RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge

Principis durant la recol·lecció d'evidències - Consideracions sobre la privacitat

- És molt important tindre en consideració les pautes de l'empresa en el que a privacitat es refereix. És habitual sol·licitar una autorització per escrit de qui corresponga per a poder dur a terme la recol·lecció d'evidències. Aquest és un aspecte fonamental ja que pot donar-se el cas que es treballa amb informació confidencial o de vital importància per a l'empresa, o que la disponibilitat dels serveis es veja afectada.
- No cal entremetre's en la privacitat de les persones sense una justificació. No s'han de recopilar dades de llocs als quals normalment no hi ha raó per a accedir, com a fitxers personals, llevat que hi haja suficients indicis.



Recopilació d'evidències

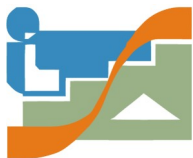
RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge

Procediment de recol·lecció - Transparència

Els mètodes utilitzats per a recol·lectar evidències han de ser transparents i reproduïbles. S'ha d'estar preparat per a reproduir amb precisió els mètodes usats, i que aquests mètodes hagen sigut testats per experts independents.

Passos

- On està l'evidència? Llistar quins sistemes estan involucrats en l'incident i de quins d'ells s'han de prendre evidències.
- Establir què és rellevant. En cas de dubte és millor recopilar molta informació que poca.
- Fixar l'ordre de volatilitat per a cada sistema.
- Obtindre la informació d'acord amb l'ordre establert.
- Comprovar el grau de sincronització del rellotge del sistema.
- Segons es vagin realitzant els passos de recol·lecció preguntar-se què més pot ser una evidència.
- Documentar cada pas.
- No oblidar a la gent involucrada. Prendre notes sobre quina gent era allí, què estaven fent, què van observar i com van reaccionar.



Recopilació d'evidències

RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge

El procediment d'emmagatzematge

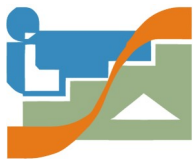
1. Cadena de custòdia

Ha d'estar clarament documentada i s'han de detallar els següents punts:

- On?, quan? i qui? va descobrir i va recol·lectar l'evidència.
- On?, quan? i qui? va manipular l'evidència.
- Qui ha custodiat l'evidència?, quant temps? i com l'ha emmagatzemada?
- En el cas que l'evidència canvie de custòdia indicar quan i com es va realitzar l'intercanvi, incloent número d'albarà, etc.

2. On i com emmagatzemar-ho

- S'ha d'emmagatzemar la informació en dispositius la seguretat dels quals haja sigut demostrada i que permeten detectar intents d'accés no autoritzats.



Recopilació d'evidències

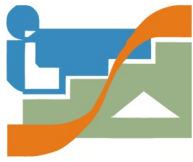
RFC 3227 - Directrius per a la recopilació d'evidències i el seu emmagatzematge

Eines necessàries

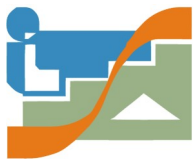
Eines necessàries

Existeixen una sèrie de pautes que han de ser seguides a l'hora de seleccionar les eines amb les quals es durà a terme el procés de recol·lecció:

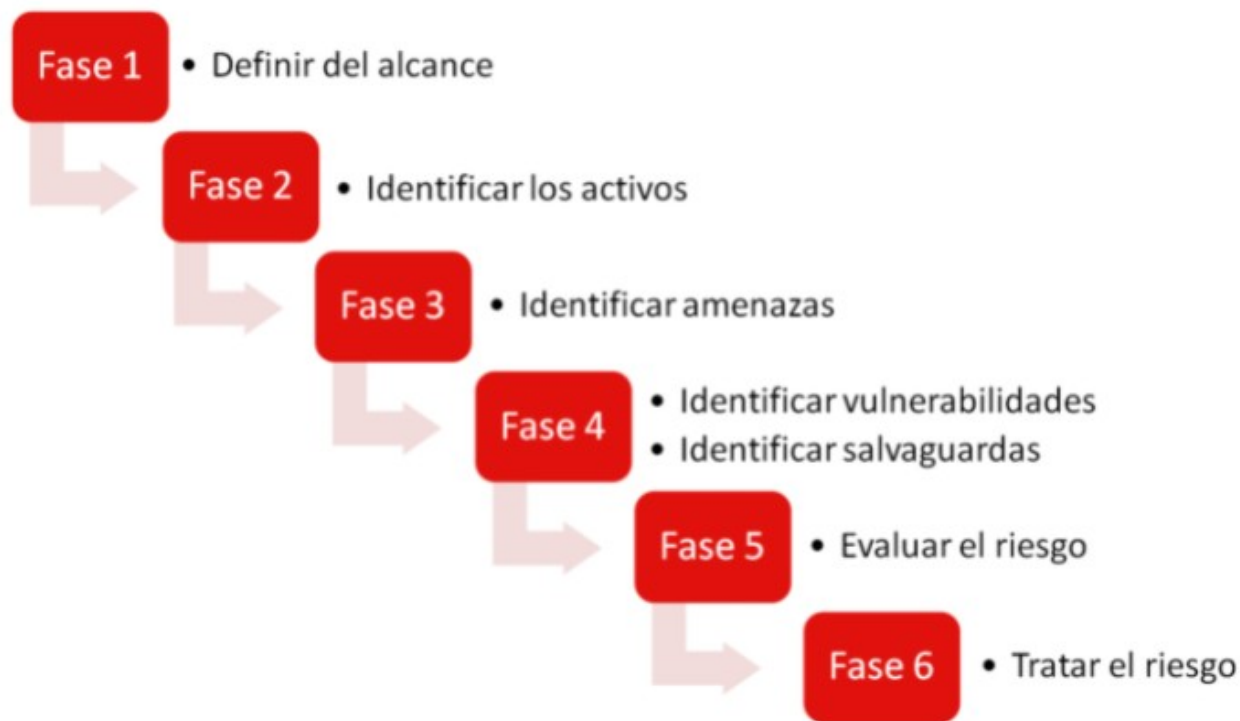
- S'han d'utilitzar eines alienes al sistema ja que aquestes poden haver-se vist compromeses, principalment en els casos de malware.
- S'ha de procurar utilitzar eines que alteren el menys possible l'escenari, evitant l'ús d'eines d'interfície gràfica i aquelles l'ús de memòria de les quals siga gran.
- Els programes que es vagen a utilitzar per a recol·lectar les evidències han d'estar situats en un dispositiu de només lectura (CDROM, pendrive protegit, etc.).
- S'ha de preparar un conjunt d'utilitats adequades als sistemes operatius amb els quals es treballa.
- El kit d'anàlisi ha d'incloure els següents tipus d'eines:
 - Programes per a llistar i examinar processos.
 - Programes per a examinar l'estat del sistema.
 - Programes per a realitzar còpies bit a bit.



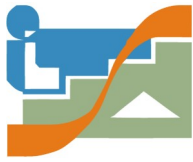
- Recopilació d'evidències
- **Anàlisi d'evidències**
- Investigació de l'incident
- Intercanvi d'informació de l'incident amb proveïdors o organismes competents
- Mesures de contenció d'incidents



Anàlisi d'evidències (riscos)



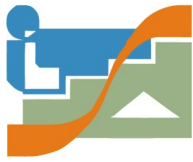
<https://www.incibe.es/protege-tu-empresa/blog/analisis-riesgos-pasos-sencillo>



Anàlisi d'evidències (riscos)

Fase 1. Definir l'abast

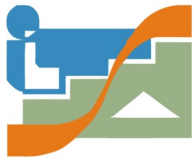
El primer pas a l'hora de dur a terme l'anàlisi de riscos, és establir l'abast de l'estudi. Considerarem que aquesta anàlisi de riscos forma part del Pla Director de Seguretat. Per tant, recomanem que l'anàlisi de riscos cobrisca la totalitat de l'abast del PDS, on s'han seleccionat les àrees estratègiques sobre les quals millorar la seguretat. D'altra banda, també és possible definir un abast més limitat atenent departaments, processos o sistemes. Per exemple, anàlisi de riscos sobre els processos del departament Administració, anàlisi de riscos sobre els processos de producció i gestió de magatzem o anàlisi de riscos sobre els sistemes TIC relacionats amb la pàgina web de l'empresa, etc. En aquest cas pràctic considerem que l'abast triat per a l'anàlisi de riscos és “Els serveis i sistemes del Departament Informàtica”.



Anàlisi d'evidències (riscos)

Fase 2. Identificar els actius

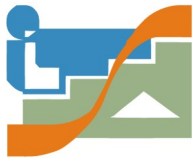
Una vegada definit l'abast, hem d'identificar els actius més importants que guarden relació amb el departament, procés, o sistema objecte de l'estudi. Per a mantindre un inventari d'actius senzill pot ser suficient amb fer ús d'un full de càlcul o taula.



Anàlisi d'evidències (riscos)

Fase 3. Identificar / seleccionar les amenaces

Havent identificat els principals actius, el següent pas consisteix a identificar les amenaces a les quals aquests estan exposats. Tal com imaginem, el conjunt d'amenaces és ampli i divers pel que hem de fer un esforç a mantindre un enfocament pràctic i aplicat. Per exemple, si la nostra intenció és avaluar el risc que correm enfront de la destrucció del nostre servidor de fitxers, és convenient, considerar les avaries del servidor, la possibilitat de danys per aigua (trencament d'una canonada) o els danys per foc, en lloc de plantejar-nos el risc que el CPD siga destruït per un meteorit.

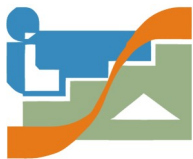


Anàlisi d'evidències (riscos)

Fase 4. Identificar vulnerabilitats i salvaguardes

La següent fase consisteix a estudiar les característiques dels nostres actius per a identificar punts febles o vulnerabilitats. Per exemple, una possible vulnerabilitat pot ser identificar un conjunt d'ordinadors o servidors els sistemes antivirus dels quals no estan actualitzats o una sèrie d'actius per als quals no existeix suport ni manteniment per part del fabricant. Posteriorment, a l'hora d'avaluar el risc aplicarem penalitzacions per a reflectir les vulnerabilitats identificades.

D'altra banda, també analitzarem i documentarem les mesures de seguretat implantades en la nostra organització. Per exemple, és possible que hàgem instal·lat un sistema SAI (Sistema d'Alimentació Ininterrompuda) o un grup electrogen per a proveir d'electricitat als equips del CPD. Totes dues mesures de seguretat (també conegudes com a salvaguardes) contribueixen a reduir el risc de les amenaces relacionades amb el tall de subministrament elèctric.



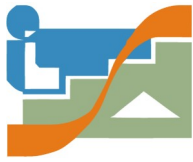
Anàlisi d'evidències (riscos)

Fase 5. Avaluar el risc

Arribat a aquest punt disposem dels següents elements:

- Inventari d'actius.
- Conjunt d'amenaques a les quals està exposada cada actiu.
- Conjunt de vulnerabilitats associades a cada actiu (si correspon).
- Conjunt de mesures de seguretat implantades

Amb aquesta informació, ens trobem en condicions de calcular el risc. Per a cada parell actiu-amenaça, estimarem la probabilitat que l'amenaça es materialitze i l'impacte sobre el negoci que això produiria. El càlcul de risc es pot realitzar usant tant criteris quantitatius com qualitatius.



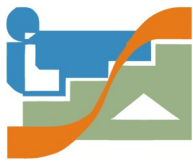
Anàlisi d'evidències (riscos)

Fase 5. Avaluar el risc

Càlcul del risc

A l'hora de calcular el risc, si hem optat per fer l'anàlisi quantitativa, calcularem multiplicant els factors probabilitat i impacte:

$RISC = PROBABILITAT \times IMPACTE.$



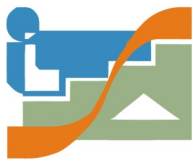
Anàlisi d'evidències (riscos)

Fase 5. Avaluar el risc

Càlcul del risc

Si per contra hem optat per l'anàlisi qualitativa, farem ús d'una matriu de risc com la que es mostra a continuació

		IMPACTO		
		Bajo	Medio	Alto
PROBABILIDAD	Baja	Muy bajo	Bajo	Medio
	Media	Bajo	Medio	Alto
	Alta	Medio	Alto	Muy alto

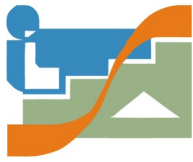


Anàlisi d'evidències (riscos)

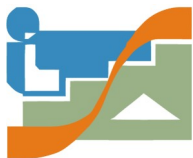
Fase 6. Tractar el risc

Una vegada calculat el risc, hem de tractar aquells riscos que superen un límit que nosaltres mateixos hàgem establert. Per exemple, tractarem aquells riscos el valor dels quals siga superior a “4” o superior a “Mitjà” en cas que hàgem fet el càlcul en termes qualitatius. A l'hora de tractar el risc, existeixen quatre estratègies principals:

- Transferir el risc a un tercer. Per exemple, contractant una assegurança que cobreixca els danys a tercers ocasionats per fugides d'informació.
- Eliminar el risc. Per exemple, eliminant un procés o sistema que està subjecte a un risc elevat. En el cas pràctic que hem exposat, podríem eliminar la wifi de cortesia per a donar servei als clients si no és estrictament necessari.
- Assumir el risc, sempre justificadament. Per exemple, el cost d'instal·lar un grup electrogen pot ser massa alt i per tant, l'organització pot optar per assumir.
- Implantar mesures per a mitigar-ho. Per exemple, contractant un accés a internet de suport per a poder accedir als serveis en el núvol en cas que la línia principal haja caigut.

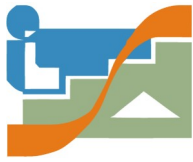


- Recopilació d'evidències
- Anàlisi d'evidències
- **Investigació de l'incident**
- Intercanvi d'informació de l'incident amb proveïdors o organismes competents
- Mesures de contenció d'incidents



Amb tècniques d'anàlisi forense

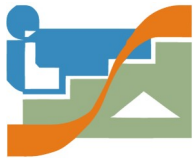




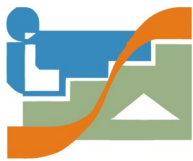
Anàlisi forense

Cada cas suposarà analitzar unes evidències

- **Comunicacions**
- **Imatge de disc**
- **Imatge de memòria**
- **Fitxers amb diversos formats**
- **Metadades**
- **Dispositius hardware**
- **Malware**



- Recopilació d'evidències
- Anàlisi d'evidències
- Investigació de l'incident
- Intercanvi d'informació de l'incident amb proveïdors o organismes competents
- Mesures de contenció d'incidents



Proveïdors -> amb email

Organismes competents

- El subjecte afectat enviarà un correu electrònic (o tiquet) al CSIRT de referència
- El CSIRT de referència, depenent de l'incident, posa en coneixement del mateix a l'organisme receptor implicat o l'autoritat nacional competent
 - Si afecta la Defensa Nacional, al ESP DEF CERT Mando Conjunto del Ciberespacio
 - Si afecta Infraestructura Crítica de la Llei PIC 8/2011, al CNPIC
 - Si afecta el RGPD, a l'AEPD.
 - Si és un incident de AAPP sota el ENS de perillositat MOLT ALTA o CRÍTICA, al CCN-CERT
 - Si és un incident d'obligatori report segons l'RD Llei 12/2018, a l'autoritat nacional competent corresponent.
 - RGPD: es remet la URL del portal de l'AEPD.
 - BDE: es remet la plantilla de notificació .XLS del BDE.
 - PIC: es remet la plantilla de notificació .XLS del CNPIC.
 - ENS: es remet la plantilla de notificació .DOC a CCN-CERT.
 - NIS: es remet la plantilla de notificació de l'autoritat nacional competent.

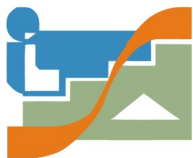


CNPIC
CENTRO NACIONAL DE PROTECCIÓN
DE INFRAESTRUCTURAS CRÍTICAS



**REAL DECRETO 43/2021:
DESARROLLO NORMATIVO DE
CIBERSEGURIDAD EN ESPAÑA
(DIRECTIVA NIS)**





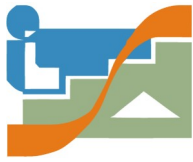
- L'Organisme receptor implicat o autoritat nacional competent es posa en contacte amb el subjecte afectat per a recaptar dades de l'incident.
- El subjecte afectat comunica les dades necessàries a l'organisme receptor implicat o autoritat nacional competent.
- Si escau, des de l'Oficina de Coordinació Cibernètica (OCC, depen de CNPIC) es posa la informació a la disposició de les Forces i Cossos de Seguretat de l'Estat i Ministeri Fiscal per a iniciar la investigació policial i judicial (art. 14.3 RD Llei 12/2018).

Con la publicación del RD 43/2021, los operadores críticos, operadores de servicios esenciales y proveedores de servicios digitales tienen la obligación de notificar sus incidentes.

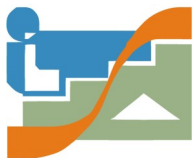
Directiva NIS – RD-L 12/2019 - RD 43/2021

https://www.incibe-cert.es/FAQ-RD_43-2021





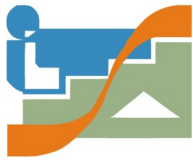
- Recopilació d'evidències
- Anàlisi d'evidències
- Investigació de l'incident
- Intercanvi d'informació de l'incident amb proveïdors o organismes competents
- **Mesures de contenció d'incidents**



En el moment que s'ha identificat un ciberincident la màxima prioritat és contindre l'impacte del mateix en l'organització de manera que es puguin evitar al més prompte possible la propagació a altres sistemes o xarxes evitant un impacte major, i l'extracció d'informació fora de l'organització.

Aquesta sol ser la fase en la qual es realitza el triage que consisteix en avaluar tota la informació disponible en eixe moment i realitzar una classificació i priorització del ciberincident en funció del tipus i de la criticitat de la informació i els sistemes afectats.

Addicionalment s'identifiquen possibles impactes en el negoci i en funció dels procediments es treballa en la presa de decisions amb les unitats de negoci apropiades i/o als responsables dels serveis.



Les mesures de mitigació dependran de la mena de ciberincident, ja que en alguns casos serà necessari comptar amb suport de proveïdors de serveis, com en el cas d'un atac de denegació de servei distribuït (DDoS), i en uns altres ciberincidents pot suposar incloc l'esborrat complet dels sistemes afectats i recuperació des d'una còpia de seguretat.

La finalitat de la fase de recuperació consisteix a retornar el nivell d'operació al seu estat normal i que les àrees de negoci afectades puguen reprendre la seua activitat. És important no precipitar-se en la posada en producció de sistemes que s'han vist implicats en ciberincidents.

Convé prestar especial atenció a aquests sistemes durant la posada en producció i buscar qualsevol signe d'activitat sospitosa, definint un període de temps amb mesures addicionals de monitoratge.